QA TEST REPORT

Freshroots Reorder Planner

Functional, security, accessibility, concurrency and load testing of the planner, its API, the Neon database and the ERPNext integration.

Tested 26 Oct 2026 Build 20f144f Rule book 2.2
Live: freshroots-reorder-planner.vercel.app ERP: freshroots.m.frappe.cloud

Verdict

The rules engine is solid; the workflow around it is not yet safe for live orders. Every reorder rule, validation check and output check held across 300 random datasets and catalogues up to 5,000 SKUs, and the live site served 650 requests under load with no errors. But 1 critical and 2 high issues mean a plan can be approved by anyone, or end up both rejected and approved, and ERPNext sync is now switched on, so those approvals create real purchase orders.

178	94%	12	0
test cases · 169 passed, 9 failed	code coverage (was 89%)	findings: 1 critical · 2 high · 4 medium · 5 low	errors in 650 load requests

Results by area

Area	What was tested	Cases	Passed	Result
Reorder rules (golden + edge)	October golden test, rule book edge cases T1–T20, determinism	38	38	PASS
Input validation	Each check I1–I12 with a deliberate fault; several faults at once; stale, future and boundary dates	28	28	PASS
File robustness and config	CRLF, UTF-8 BOM, padded cells, extra and reordered columns, binary, UTF-16, semicolons, header-only, Unicode names; bad config refused; threshold changes flow through	9	9	PASS

Area	What was tested	Cases	Passed	Result
Output checks O1–O8	Each pre-send check fails when its rule is deliberately broken	7	7	PASS
Fuzzing and scale	300 random datasets (rules hold, quantities 0/1×/1.5×, deterministic); 1,000 SKUs × 52 weeks; 5,000 SKUs × 16 weeks	3	3	PASS
API and roles	Role matrix, missing or fake roles, workflow locking, 404s, PO numbering, notes, audit trail, inputs, path traversal, 5,000-SKU upload	19	19	PASS*
ERPNext (mocked)	Create, retry, idempotency, 401/500/HTML/timeout/refused, disabled supplier, missing item, submit validation and failure	17	17	PASS
ERPNext (live)	Throwaway PO: create, re-create, submit with rate, second submit, cancel	4	4	PASS
AI explanations	Number guardrail (invented price or quantity, injection, length), Gemini failure and malformed replies	11	11	PASS
Security	Markup in PDFs, formula injection in 4 exports, secrets in responses, SQL-like input	7	3	4 FAIL
Concurrency	Double approval, approve vs reject, parallel approvals, 15 parallel uploads (4 workers, development database)	4	1	3 FAIL
Website (live)	Accessibility scan on 10 pages, phone layout on 10 pages, phone menu, keyboard and focus, role guards	25	23	2 FAIL
End-to-end	Upload → plan → approve → POs → downloads; latest SAP data → reject; Data and Guide pages	3	3	PASS
Load (live, read-only)	650 requests at 5, 20 and 50 concurrent users over 7 pages and API calls	3	3	PASS*

* Passed functionally, with performance or design findings listed below. Three accessibility flags on animated pages were the scanner catching content mid-fade; they cleared once the animation settled and are not counted as defects.

Findings

CRITICAL SEC-A Anyone can act as Raghav and approve a plan

What	The sign-in is a role picker; the API trusts an `X-Role` header that any browser or script can set. With ERPNext sync on, an approval by anyone creates real Draft POs.
Evidence	AUTH-1/AUTH-2: a request with `X-Role: raghav` and no other credentials is accepted.
Fix	Real sign-in (e.g. Google or email link) with roles stored server-side; until then, keep the URL private or switch ERPNext sync off.

HIGH BUG-2 Approve and reject at the same moment both succeed

What	Two clicks (two tabs, or approve then reject quickly) both pass the "still a draft?" check. Both report success; the plan ends up approved with POs while carrying the reject note.
Evidence	RACE-2, plan #18 on the development database: audit log reads created → rejected → approved.
Fix	Lock the plan row while deciding (`SELECT … FOR UPDATE`) or update only `WHERE status = 'draft'` and check one row changed.

HIGH BUG-3 Approving two plans at once fails with a server error

What	PO numbers are counted, not reserved, so simultaneous approvals pick the same number and the database rejects the duplicate. The failed approval is rolled back cleanly and can be retried.
Evidence	RACE-3: 3 plans approved together → 1 succeeded, 2 returned 500; no partial data left behind.
Fix	Reserve the number inside the same lock as BUG-2, or retry on a duplicate-number error.

MEDIUM BUG-1 Formula injection in Excel and CSV exports

What	A product or supplier name starting with `=` becomes a live formula (for example a hyperlink) when the export is opened in Excel. Affects the plan Excel, PO Excel, plan CSV and PO CSV.
Evidence	SEC-2 ×4, marked as expected failures in the test suite until fixed.
Fix	Prefix text that starts with `= + - @` with an apostrophe and store Excel cells as text.

MEDIUM PERF-1 The plan list slows down as plans accumulate

What — Each plan in the list triggers its own database queries, about 115 ms per plan from a laptop (36 plans took 4.2 s) and about 16 ms per plan on Vercel. Home and Plans both load the full list.

Fix — Load approvals and SKU counts for all plans in one query, and page the list (latest 50).

MEDIUM LIMIT-1 **Large SAP uploads exceed Vercel's 4.5 MB request limit**

What — 5,000 SKUs with 52 weeks of sales is a 5.4 MB upload. The planner handles it in 2–3 s locally, but Vercel refuses request bodies over 4.5 MB.

Fix — Keep uploads to 16 weeks (all the rules need), or upload files directly to storage and process them from there.

MEDIUM SEC-B **No rate limiting on the API**

What — The load test reached 130 requests per second with nothing throttling it; uploads and Gemini explanations are the expensive calls.

Fix — Add Vercel's firewall rate limits for `/api/runs` and `/explain` once real sign-in exists.

LOW BUG-4

A repeated approval can return a server error instead of "already decided"

What — 10 simultaneous approvals of one plan: data stayed correct (3 POs), 8 got a clear 409, 1 got a 500.

Fix — Resolved by the BUG-2 lock.

LOW PERF-2 **Cold starts of 6–7 seconds**

What — When Vercel starts a fresh copy of the Python backend, the first request waits 6–7 s (p99 at 20 users). Warm requests take 160–400 ms.

Fix — Keep one instance warm, or load pandas only when a plan is run.

LOW PERF-3 **Submitting a PO to ERPNext takes about 7 seconds**

What — Live check: create 2.1 s, update and submit 7.3 s. The button shows "Submitting..." throughout, so it's usable, but it feels slow.

Fix — Send rates and submission in one ERPNext call.

LOW A11Y-1 **Plans list isn't announced as a list to screen readers**

What	List items are wrapped in an animation container instead of sitting directly in the list (axe: list, listitem).
Fix	Put the animation on the list item itself.

LOW A11Y-2 **"More options" text is slightly low-contrast**

What	Blue on light grey measures 4.31:1 on New run; the minimum is 4.5:1.
Fix	Use the darker blue already used on the Guide labels.

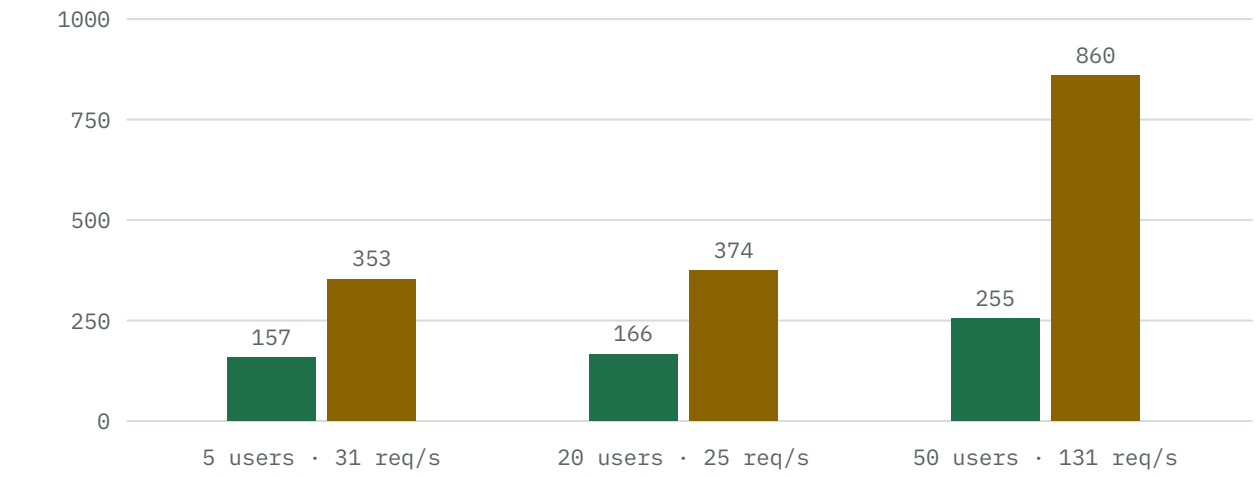
Concurrency tests

Run against a 4-worker copy of the API on the Neon development branch, so no production data was touched.

Test	Scenario	Outcome	Result
RACE-1	10 simultaneous approvals of one plan	3 POs (correct); 1 × 200, 8 × 409, 1 × 500	BUG-4
RACE-2	Approve and reject at the same moment	Both returned 200; plan approved with reject note	BUG-2
RACE-3	3 different plans approved together	1 × 200, 2 × 500; failures rolled back cleanly	BUG-3
RACE-4	15 analysts uploading at once	15/15 succeeded, unique plan numbers, 11.8 s total	PASS

Load test on the live site

Read-only requests spread evenly over the Home and Guide pages and five API calls. Median (p50) and 95th-percentile (p95) response times, in milliseconds.



Endpoint at 50 users	p50 ms	p95 ms	Errors
Home page	129	176	0
Guide page	128	177	0
Health check	200	249	0
Plan list	397	1,107	0
Plan detail (#13)	301	2,229	0
Master data	307	2,238	0
Purchase orders	274	826	0

Rules engine under stress

Test	Input	Result
F-1	300 random datasets, 1–25 SKUs, 1–30 weeks, stock 0–50,000, festival on/off	No crash; all 8 output checks passed every time; quantities always 0, 1× or 1.5× standard; identical output on re-run
S-1	1,000 SKUs × 52 weeks (52,000 sales rows)	1.29 s, all checks passed
S-1	5,000 SKUs × 16 weeks (80,000 sales rows)	2.68 s, all checks passed

Test	Input	Result
IN-3	5,000-SKU upload through the API	Accepted and planned in one request (local; see LIMIT-1 for Vercel)

Live ERPNext check

A throwaway PO `PUR-ORD-2026-00004` (1 unit of SKU001, title `QA-TEST-…`) was created, submitted with a ₹1.00 rate and Required By 30 Oct, then cancelled. It's safe to delete in ERPNext.

Check	Result	Time
Create Draft PO via API	PASS Draft created	2.1 s
Create the same PO again	PASS Same PO returned, no duplicate	–
Submit with rate and Required By	PASS Status "To Receive and Bill"; rate and date saved	7.3 s
Submit a second time	PASS Refused: already submitted	–

Recommended order of fixes

1. **SEC-A** real sign-in, or switch ERPNext sync off until it exists.
2. **BUG-2, BUG-3, BUG-4** lock the plan and reserve PO numbers in one transaction.
3. **BUG-1** neutralise formulas in all Excel and CSV exports.
4. **PERF-1, LIMIT-1** batch the plan-list queries; document the 16-week upload or move uploads to storage.
5. **A11Y-1, A11Y-2, PERF-2, PERF-3, SEC-B** as polish.

Not covered

- Safari and Firefox (all browser tests ran in Chromium, including phone sizes).
- A real Gemini outage on the live site (failures were simulated; the fallback is tested).
- Real SAP exports beyond the October fixture and synthetic data.
- Penetration testing beyond the cases listed, and Neon or Vercel outages.
- Submitting a real PO with real prices (the live check used a cancelled throwaway PO).

How to re-run

```
make test                                   # 139 Python tests, incl. QA suites
.venv/bin/python -m pytest --cov=reorder --cov=planner_api
npx playwright test e2e/reorder.spec.ts     # end-to-end flows
E2E_BASE_URL=https://freshroots-reorder-planner.vercel.app npx playwright test e2e/qa
python scripts/qa_stress.py race http://127.0.0.1:8100   # needs a local multi-worker
python scripts/qa_stress.py load https://freshroots-reorder-planner.vercel.app
```

Test code: `tests/test_qa_engine.py`, `tests/test_qa_api.py`, `e2e/qa.spec.ts`, `scripts/qa_stress.py` in the GitHub repo.